

Security Audit SUMMARY – hermes-desktop

Field	Value
Date (UTC)	2026-05-02
Project	hermes-desktop
Commit	72d7bcc
Reports consolidated	5/5
Orchestrator	audit-orchestrator
Auditors run	electron-hardening-auditor, shell-and-process-auditor, secrets-and-credentials-auditor, supply-chain-auditor, network-and-storage-auditor

Executive summary

hermes-desktop's main process is mostly disciplined (argv-array spawns, parameterized SQL, contextIsolation default-on, clean .env/auth.json git history), but it ships with a sandboxless renderer that has webViewTag enabled and 60 IPC handlers that forward renderer-controlled input straight into shell commands, CLI argv, filesystem paths, and .env/YAML config files. The two highest-impact themes are (1) ~~renderer-to-host RCE primitives via sandbox: false + webViewTag: true + an unguarded shell.openExternal + a stray execSync in runHermesDoctor,~~ and (2) ~~credential exposure: API keys and bearer tokens are written to ~/.hermes/~~ {auth.json,.env,desktop.json} with default umask permissions and shipped raw to the renderer via get-env/get-credential-pool. Packaging is weak (notarize off, hardened-runtime exemptions, no @electron/fuses, ad-hoc codesign) so the auto-updater's GitHub feed is the only line of defense against a compromised release. Supply chain is otherwise clean (962 lockfile entries, 0 missing integrity, 0 non-HTTPS) but four open advisories (vite, @xmldom/xmldom, lodash, postcss) need npm audit fix. Network posture is good (TLS defaults intact, loopback bind, parameterized FTS5) except remote-mode accepts http:// and the streaming chat POST has no socket timeout.

Severity matrix (aggregated)

Severity	Count	Note
Critical	3	Renderer sandbox-off, webViewTag without guard, execSync template injection
High	16	Navigation/openExternal abuse, IPC argv injection, credential file modes, IPC raw-key leak, dependency CVEs, cleartext bearer
Medium	23	CSP gaps, fuses unset, packaging signing, path-traversal in profile/skill, FTS5 DoS, atomic-write missing

Low	13	Logging surfaces, stale config, license unknown, dev-vs-prod feed
Info	14	Positive observations (preload narrow, parameterized SQL, loopback bind, TLS defaults)
Total	69	

Per-report counts: EH 17 (2C/4H/5M/4L/2I), SP 19 (1C/4H/7M/3L/4I), SC 12 (0C/4H/3M/2L/3I), DEP 11 (0C/3H/4M/1L/3I), NS 12 (0C/1H/4M/3L/4I).

Top 10 actionable items

#	ID(s)	Severity	File	Title	Owner hint
1	EH-001	Critical	src/main/index.ts:135-139	sandbox: false on the only BrowserWindow	Electron core
2	EH-002	Critical	src/main/index.ts:135-139	webviewTag: true with no will-attach-webview guard	Electron core
3	SP-001	Critical	src/main/installer.ts:229	execSync template injection in runHermesDoctor	Main process
4	EH-003	High	src/main/index.ts:170-173, 640-642	shell.openExternal accepts any URL scheme	Main process
5	EH-004	High	src/main/index.ts:122-180	Missing will-navigate/will-redirect guards	Electron core
6	EH-005 ≈ SP-003	High	src/main/index.ts:648-652, src/main/installer.ts:601, src/main/profiles.ts:187,213,238, src/main/skills.ts:138,246,275, src/main/cronjobs.ts:117-135	IPC argv injection via profile/skill/archive/cron names	Main process
7	SC-001, SC-002, SC-007	High	src/main/utils.ts:40-44, src/main/config.ts:30-35,124-155,377-379	auth.json/.env/desktop.json written without mode 0o600	Main process
8	SC-003, SC-004	High	src/main/index.ts:238,538, src/main/config.ts:91-122,381-386	IPC get-env/get-credential-pool return raw secrets to renderer	IPC / Main process
9	DEP-001, DEP-002, DEP-003, DEP-004	High/Med	package-lock.json	vite ≤7.3.1, @xmldom/xmldom ≤0.8.12, lodash ≤4.17.23, postcss	Build

				<8.5.10 advisories	
10	NS-001	High	src/main/hermes.ts:17-25,31-37,303-304	Remote URL accepts http://; bearer token sent in cleartext	Main process / Network

Tie-breakers: items 1–3 are critical and one-line fixes (sandbox: true, drop webViewTag, replace execSync↵ execFileSync)Items 4–6 are the renderer-to-host RCE chain. Items 7–8 close the highest-impact credential exposure with an inexpensive mode 0o600 + IPC mask change. Items 9–10 are the only High-severity findings outside main.

Findings by area

Electron hardening (EH-001...EH-019)

- EH-001 src/main/index.ts:135-139 – sandbox: false on the only BrowserWindow.
- EH-002 src/main/index.ts:135-139 – webViewTag: true enabled with no will-attach-webview guard.
- EH-003 src/main/index.ts:170-173, 640-642 – setWindowOpenHandler/open-external forward any URL to shell.openExternal without scheme allow-list.
- EH-004 src/main/index.ts:122-180 – Missing will-navigate/will-redirect guards.
- EH-005 src/main/index.ts:648-652, src/main/installer.ts:592-630 – IPC handlers spawn child processes with renderer-supplied arguments (no argv-flag guard).
- EH-006 src/main/index.ts:240-266 – set-env/set-config write renderer input to disk without sanitisation.
- EH-007 src/main/index.ts:182-671 – IPC handlers do not authenticate the sender frame.
- EH-008 src/main/installer.ts:486-502 – bash -c install string + curl | bash with no checksum.
- EH-009 src/renderer/index.html:6-9 – CSP allows 'unsafe-inline' styles; missing connect-src/frame-ancestors/object-src/base-uri.
- EH-010 src/main/index.ts (search) and src/renderer/index.html:6-9 – CSP enforced only via <meta>; no onHeadersReceived policy.
- EH-011 build/entitlements.mac.plist:1-15, build/entitlements.mac.inherit.plist:1-15 – Hardened-runtime entitlements weaken codesigning protections.
- EH-012 electron-builder.yml:32, 53-58, src/main/index.ts:792-841 – Auto-updater publishes via GitHub on unsigned, unnotarized binary.
- EH-013 package.json:27-67, electron-builder.yml – @electron/fuses not used; runtime hardening fuses unset.
- EH-014 electron-builder.yml:1-58 – ASAR integrity not enforced.
- EH-015 src/main/index.ts:375-385 – chat-error Notification body shows untrusted gateway error string verbatim.
- EH-016 src/main/index.ts:154-161 – console-message dev hook left in production build.
- EH-017 src/main/index.ts:735-741, 848-850 – Dev menu reload/devtools gated, but webPreferences.devTools not explicitly disabled in prod.
- EH-018 src/main/index.ts:135-139 – Info: contextIsolation default true, nodeIntegration default false (positive).
- EH-019 src/preload/index.ts:1-650 – Info: preload bridge does not leak Node primitives

(positive).

Shell & process (SP-001...SP-019)

- SP-001 src/main/installer.ts:229 – Command injection via execSync string concatenation in runHermesDoctor (HERMES_HOME-controlled).
- SP-002 src/main/installer.ts:486-492 – spawn("bash", ["-c", installCmd]) sources shell-profile path into shell string + curl | bash.
- SP-003 src/main/profiles.ts:187,213,238, src/main/skills.ts:138,246,275, src/main/installer.ts:601, src/main/cronjobs.ts:117-135,142-170 – Profile/skill/archive identifiers reach execFileSync without validation (argv flag-injection).
- SP-004 src/main/claw3d.ts:451-462,526-536, src/main/hermes.ts:677-684 – Detached children (dev server, adapter, gateway) survive main-process crash with full env (incl. API keys).
- SP-005 src/main/skills.ts:122-131, src/main/index.ts:507-509 – Renderer-sourced skillPath reaches path.join without containment check.
- SP-006 src/main/installer.ts:34-51 – getEnhancedPath() prepends home-owned bin dirs ahead of system PATH.
- SP-007 src/main/installer.ts:288-298,344-355,492-502 – runInstall/runHermesUpdate/runClawMigrate have no timeout.
- SP-008 src/main/claw3d.ts:274-289 – findNpm() falls through to a shell-fallback which npm/ where npm invocation.
- SP-009 src/main/utils.ts:22-26 (and many call sites) – Renderer-supplied profile reaches path.join without validation; can escape ~/.hermes/profiles.
- SP-010 src/main/installer.ts:857-879 – readLogs allow-list covers logFile but not the lines parameter (memory amplification).
- SP-011 src/main/claw3d.ts:421-440,498-517,570-589, src/main/hermes.ts:719-747 – process.kill(-pid, "SIGKILL") race after 3 s timeout; stopGateway inconsistent with rest.
- SP-012 src/main/hermes.ts:95-115, src/main/config.ts:124-155,170-189,220-267,297-354,388-399, src/main/tools.ts:193-293 – appendFileSync/safeWriteFile mutate config.yaml without locking (TOCTOU).
- SP-013 src/main/installer.ts:493 – runInstall sets cwd: home instead of an isolated temp directory.
- SP-014 src/main/cronjobs.ts:97-115 – runCronCommand has no env whitelist (inherits API keys).
- SP-015 src/main/installer.ts:582-588 – runHermesBackup returns untrusted regex-scraped path string to renderer.
- SP-016 (info) src/main/profiles.ts, src/main/skills.ts, src/main/cronjobs.ts, src/main/installer.ts – execFile/argv arrays used consistently; no shell: true (positive).
- SP-017 (info) src/main/askpass.ts – Sudo password never embedded in argv/logs/env (positive).
- SP-018 (info) src/main/installer.ts:11 – Renderer cannot mutate main HERMES_HOME directly (mitigates SP-001).
- SP-019 (info) src/main/sessions.ts:38, src/main/memory.ts:87, src/main/session-cache.ts:75-78 – Better-sqlite3 readonly + parameter binding (positive).

Secrets & credentials (SC-001...SC-012)

- SC-001 src/main/config.ts:377-379, src/main/utils.ts:40-44 – auth.json (credential pool) written without explicit mode 0o600.
- SC-002 src/main/config.ts:124-155, src/main/utils.ts:40-44 – .env provider keys written

without explicit mode 0o600.

- SC-003 src/main/index.ts:238, src/main/config.ts:91-122, src/preload/index.ts:64-65, src/renderer/src/screens/Providers/Providers.tsx:37,41,107 — IPC get-env returns raw API keys to renderer.
- SC-004 src/main/index.ts:538, src/main/config.ts:381-386, src/preload/index.ts:378-380, src/renderer/src/screens/Providers/Providers.tsx:39,45,118-128 — IPC get-credential-pool returns raw key material to renderer.
- SC-005 src/main/utils.ts:40-44, src/main/config.ts:34,154,188,266,353,378 — Atomic write missing for credential and env files (silent loss on crash).
- SC-006 src/main/config.ts:31-34, src/main/utils.ts:42 — ~/.hermes created without explicit restrictive mode.
- SC-007 src/main/config.ts:30-35,46-52, src/main/index.ts:306-312, src/main/hermes.ts:33-34 — Remote-mode bearer cached in desktop.json without mode 600.
- SC-008 src/main/index.ts:240-254,539-549,111-117 — Global console.error of uncaught/unhandled errors has no secret redaction layer.
- SC-009 src/renderer/src/constants.ts:51,64,75,87,99,123 — Placeholder strings near real key shape can confuse secret scanners.
- SC-010 (info) .gitignore:21-23 — .env/.env.* correctly ignored; recommend adding auth.json, desktop.json (positive).
- SC-011 (info) Repository-wide — No live secrets in git history (positive).
- SC-012 (info) src/renderer/src/screens/Settings/*, src/renderer/src/components/{I18nProvider,ThemeProvider}.tsx — localStorage holds only display caches (positive).

Supply chain (DEP-001...DEP-011)

- DEP-001 package-lock.json — vite@7.3.1: arbitrary-file-read + path-traversal + server.fs.deny bypass (fix ≥7.3.2).
- DEP-002 package-lock.json — @xmldom/xmldom@0.8.12: four high DoS / XML-injection issues (fix ≥0.8.13).
- DEP-003 package-lock.json — lodash@4.17.21: prototype pollution + _.template code injection (fix ≥4.17.24).
- DEP-004 package-lock.json — postcss@8.5.8: XSS via unescaped </style> (fix ≥8.5.10).
- DEP-005 package.json: ^39.2.6 / lockfile 39.8.5 — Electron two minor patches behind 39.8.9.
- DEP-006 package.json — i18next 25 & 26 and react-i18next 15 & 17 (one and two majors behind).
- DEP-007 package.json — electron-updater@6.3.9 & 6.8.3 (auto-update channel five minor releases behind).
- DEP-008 package.json: postinstall, package-lock.json — Build chain pulls native installers (electron, better-sqlite3, esbuild, electron-winstaller, fsevents); use npm ci + --ignore-scripts for CI.
- DEP-009 package-lock.json — format@0.2.2 UNKNOWN license shipped in production bundle via react-syntax-highlighter chain.
- DEP-010 package-lock.json — better-sqlite3@12.8.0 & 12.9.0 (one minor behind).
- DEP-011 (info) package-lock.json — Lockfile/registry posture clean: 962 packages, 0 missing integrity, 0 non-HTTPS, 0 non-registry (positive).

Network & storage (NS-001...NS-012)

- NS-001 src/main/hermes.ts:17-25,31-37,303-304,765-789 — Remote API URL accepts plaintext http://; bearer token sent in cleartext.
- NS-002 src/main/hermes.ts:303-311,312-381 — Streaming chat POST has no socket timeout;

bearer pinned in memory on half-open TCP.

- NS-003 src/main/index.ts:306-312, src/main/config.ts:46-52, src/main/hermes.ts:486-489 — Remote URL accepted from renderer without scheme/host validation; loopback regex is loose substring match.
 - NS-004 src/main/sessions.ts:36-39, src/main/session-cache.ts:75-78, src/main/memory.ts:87 — SQLite DB opened without timeout/fileMustExist; can wedge UI under exclusive write lock.
 - NS-005 src/main/sessions.ts:100-126 — FTS5 MATCH sanitizer strips " but leaves : and unbounded token count (DoS surface).
 - NS-006 dev-app-update.yml:1-4, electron-builder.yml:54-57 — Dev and prod feeds both bound to fathah/hermes-desktop; macOS unnotarized.
 - NS-007 src/main/index.ts:375-385, src/main/hermes.ts:316-330,560-566 — Desktop notification body and chat-error IPC echo upstream error string verbatim (token-prefix leak risk).
 - NS-008 src/main/index.ts:154-161 — Unconditional process logging of renderer console at level ≥ warn writes raw renderer output to main stdout.
 - NS-009 (info) src/main/sessions.ts:48-60,111-126,159-164, src/main/session-cache.ts:88-94,122-126, src/main/memory.ts:88-94 — All db.prepare(...) use bound parameters (positive).
 - NS-010 (info) src/main/hermes.ts:17,101-114, src/main/claw3d.ts:108-110,127 — Hermes local API bound to 127.0.0.1:8642, not 0.0.0.0 (positive).
 - NS-011 (info) src/main/hermes.ts — TLS validation left at Node defaults; no rejectUnauthorized: false (positive).
 - NS-012 (info) src/main/installer.ts:857-879 — read-logs IPC accepts only mandatory log file names (positive).
-

Cross-agent overlaps

The following findings overlap or stack across reports — fix the underlying issue once and resolve all listed IDs:

- **EH-005 ≈ SP-003** — Renderer-controlled IPC arguments forwarded into execFileSync/spawn argv (profile names, skill IDs, archive paths, cron name/schedule). Same root cause: no input validation. src/main/index.ts:648-652, src/main/installer.ts:601, src/main/profiles.ts:187,213,238, src/main/skills.ts:138,246,275, src/main/cronjobs.ts:117-135.
- **EH-006 ≈ SC-001/SC-002/SC-007** — set-env/set-config/set-credential-pool write renderer input to disk without sanitisation AND without mode 0o600. EH treats it as input-validation; SC treats it as file-permission. Fix together with a hardened safeWriteFile (atomic temp+rename, mode: 0o600, chmodSync, key/value validation).
- **EH-008 ≈ SP-002 ≈ SP-013** — installer.ts:486-502's bash -c curl | bash install path. EH-008 = supply chain integrity, SP-002 = command injection via shellProfile, SP-013 = cwd: home exposure to user dotfiles.
- **EH-012 ≈ NS-006** — Auto-updater on unsigned/unnotarized macOS binary, fathah/hermes-desktop GitHub feed, no Authenticode on Windows. Same fix: real signing + notarization + mac.notarize: true.
- **EH-015 ≈ NS-007** — chat-error Notification body shows untrusted upstream error string verbatim. Same call site src/main/index.ts:375-385. EH frames as phishing/UI; NS adds bearer-prefix leak risk.

- **EH-016 ≈ NS-008** — `src/main/index.ts:154-161` console-message renderer hook leaks renderer logs into main stdout / system log. Same line range, two reports.
 - **EH-005 (cron part) ≈ SP-014** — `src/main/cronjobs.ts` cron handlers: EH-005 covers argv flag-injection on schedule/prompt/name; SP-014 covers env inheritance leaking API keys to the cron child.
 - **SP-005 ≈ SP-009** — Path traversal: `skillPath` (SP-005) and `profile` (SP-009) both flow into `path.join` from renderer with no allow-list. Single hardener helper resolves both.
 - **EH-005 (set-env part) ≈ EH-011** — Combined primitive: renderer can write `DYLD_INSERT_LIBRARIES` / `LD_PRELOAD` into `.env`, and macOS hardened runtime allows dyld env vars and disables library validation. The two must be fixed together to neutralize the dylib-injection path.
 - **SP-001 ≈ SP-018** — SP-001 is the `execSync` template injection in `runHermesDoctor`; SP-018 is the mitigating note that renderer cannot mutate `HERMES_HOME` at runtime. Pre-conditions narrow the attacker model but don't eliminate it.
 - **DEP-001 ≈ DEP-004** — `vite ≥ 7.3.2` upgrade also pulls in `postcss ≥ 8.5.10`. One bump closes both.
-

Remediation roadmap

Now (Critical — ship before next release)

- **EH-001** — Set `sandbox: true` and `explicitContextIsolation: true` in `webPreferences` (`src/main/index.ts:135-139`).
- **EH-002** — Remove `webViewTag: true`, or register `web-contents-created` ⓘ `will-attach-webview` deny-by-default handler.
- **SP-001** — Replace the `execSync` template literal in `runHermesDoctor` with `execFileSync(HERMES_PYTHON, [HERMES_SCRIPT, "doctor"], ...)` (`src/main/installer.ts:229`).

Next sprint (High + cross-agent overlaps)

- **EH-003 / EH-004** — Add `will-navigate/will-redirect` guards and validate `details.url` and the open-external argument with new URL + scheme allow-list (https: only).
- **EH-005 ≈ SP-003** — Centralized argv-safe validator (reject leading -, max length, identifier regex `^[A-Za-z0-9._-]{1,64}$`); apply to every IPC handler that forwards into `execFile/spawn`. Insert — before free-form CLI args.
- **EH-006 ≈ SC-001/SC-002/SC-007 ≈ SC-005/SC-006** — Harden `safeWriteFile` to atomic `temp+rename` with `{ mode: 0o600 }` + `chmodSync` after write; `mkdirSync(HERMES_HOME, { recursive: true, mode: 0o700 })`; key/value sanitisation for `set-env/set-config/set-credential-pool`.
- **SC-003 / SC-004** — Switch `get-env/get-credential-pool` IPC contracts to return masked metadata only; add gated `reveal-env-value` IPC.
- **EH-007** — Add `assertTrustedSender(event)` helper checking `event.senderFrame` and call at top of every handler.
- **EH-008 ≈ SP-002 ≈ SP-013** — Drop `bash -c` shell-string indirection; pin `install-script` SHA-256; use `os.tmpdir()` `cwd`.
- **EH-012 ≈ NS-006** — Acquire Apple Developer ID + Authenticode certs; set `mac.notarize: true`, configure `mac.identity` and `win.certificateFile`; enforce 2FA on the publishing account.

- **EH-013** — Add @electron/fuses direct dep; flip RunAsNode: false, EnableNodeOptionsEnvironmentVariable: false, EnableNodeCliInspectArguments: false, OnlyLoadAppFromAsar: true, EnableEmbeddedAsarIntegrityValidation: true, EnableCookieEncryption: true.
- **NS-001 / NS-003** — Reject non-https:// remote URLs (loopback exception by exact-match hostname); new URL validation in set-connection-config.
- **SP-004** — Drop detached: true on dev server / adapter; centralize child-process shutdown on SIGINT/SIGTERM/uncaughtException.
- **SP-005 ≈ SP-009** — path.resolve + base-dir containment check helper; enforce `^[A-Za-z0-9._-]{1,64}$` on profile.
- **DEP-001...DEP-004** — npm audit fix: vite ≥ 7.3.2, @xmldom/xmldom ≥ 0.8.13, lodash ≥ 4.17.24 override, postcss ≥ 8.5.10 (transitive via vite).

Backlog (Medium + Low + Info follow-ups)

- **EH-009 / EH-010** — Tighten CSP (connect-src 'self' http://127.0.0.1:* ws://127.0.0.1:*; base-uri, object-src 'none', frame-ancestors 'none'); enforce via session.defaultSession.webRequest.onHeadersReceived.
- **EH-011** — Drop allow-unsigned-executable-memory, allow-dyld-environment-variables, disable-library-validation entitlements.
- **EH-014** — Combine fuses fix with asarIntegrity headers in electron-builder.yml.
- **EH-015 ≈ NS-007** — Replace verbatim notification body with static string; redact Bearer ..., sk-..., apikey= patterns before display.
- **EH-016 ≈ NS-008** — Gate console-message hook behind is.dev.
- **EH-017** — Set webPreferences.devTools: !app.isPackaged.
- **SP-006 / SP-008** — Move home-owned bin dirs after system dirs; resolve git/npm/bash via absolute paths under safe PATH.
- **SP-007** — Add wall-clock timeout (e.g. 30 min) to long-running installs.
- **SP-010** — Clamp lines to [0, 5000] in readLogs.
- **SP-011** — Use process.kill(-pid) consistently in stopGateway; verify pgid before SIGKILL.
- **SP-012** — Add proper-lockfile (or .lock companion) for config.yaml/.env/auth.json mutations.
- **SP-014** — Pass explicit env whitelist to runCronCommand.
- **SP-015** — Replace stdout regex-scrape with JSON output from Hermes CLI.
- **SC-008** — Add redaction wrapper for uncaughtException/unhandledRejection global error handlers.
- **SC-009** — Add # pragma: allowlist secret markers (or rephrase) to constants.ts placeholders.
- **SC-010 follow-up** — Add auth.json, desktop.json to .gitignore.
- **DEP-005** — Refresh Electron resolution to 39.8.9 within existing caret.
- **DEP-006** — Plan i18next 25 → 26 and react-i18next 15 → 17 migration.
- **DEP-007** — Bump electron-updater to 6.8.3.
- **DEP-008** — Switch CI to npm ci; consider --ignore-scripts for non-build steps.
- **DEP-009** — Replace or override format@0.2.2 to remove UNKNOWN license.
- **DEP-010** — Bump better-sqlite3 to 12.9.0.
- **NS-002** — Add timeout: 60_000 and req.on("timeout", ...) to streaming chat POST.
- **NS-004** — Open SQLite with { readonly: true, fileMustExist: true, timeout: 2000 }.
- **NS-005** — Cap FTS5 token count and per-token length; whitelist token chars.

Methodology

Reports read

Report	Path	Size
electron-hardening.md	docs/audits/2026-05-02/electron-hardening.md	~46.5 KB / 665 lines
shell-and-process.md	docs/audits/2026-05-02/shell-and-process.md	~37 KB / 533 lines
secrets-and-credentials.md	docs/audits/2026-05-02/secrets-and-credentials.md	~20.4 KB / 264 lines
supply-chain.md	docs/audits/2026-05-02/supply-chain.md	~17.7 KB / 240 lines
network-and-storage.md	docs/audits/2026-05-02/network-and-storage.md	~21.3 KB / 452 lines

All five reports present; none missing.

Dedup heuristic

Two findings are merged into a single overlap entry when:

1. Same file:line (or overlapping line range) in both reports, OR
2. Same root cause across distinct call sites (e.g. EH-005 + SP-003 both target renderer-controlled IPC argv across index.ts:648-652, installer.ts:601, profiles.ts:*, skills.ts:*, cronjobs.ts:*)).

Overlap entries cite all source IDs (EH-005 ≈ SP-003) – the original IDs are preserved, never collapsed or renumbered. Each ID also remains listed in its area subsection.

Ranking rule

Sort by severity (Critical > High > Medium > Low > Info), then by file path within each severity. Top-10 picks Critical first, then High; ties broken by ease-of-fix vs. blast-radius (e.g. SP-001 is one-line execFileSync swap with full RCE prevention; SC-001/SC-002/SC-007 collapse into a single safeWriteFile hardener that closes three Highs).

Discipline notes

- All IDs preserved verbatim from source reports (EH-NNN, SP-NNN, SC-NNN, DEP-NNN, NS-NNN); no renumbering.
- All file:line citations quoted verbatim from source reports.
- No specialist report was modified.
- No project source file was modified.

